

ASSIGNMENT BRIEF

HTU Course No: 00203400	HTU Course Name: Risk Analysis & Systems Testing
BTEC Unit Code:	BTEC UNIT Name:



Student Name/ID Number/Section	
HTU Course Number and Title	00203400 Risk Analysis & Systems Testing
BTEC Unit Code and Title	
Academic Year	2025-2026 1
Assignment Author	Rahmeh Ibrahim
Course Tutor	Rahmeh Ibrahim
Assignment Title	Smart University Online Examination System (SOES)
Assignment Ref No	1
Issue Date	16/11/2025
Formative Assessment dates	From 19/11/2025 to 15/01/2026
Submission Date	24/01/2026
IV Name & Date	Elham Derbas 15/11/2025

Submission Format

Each student is expected to individually submit his/her work including:

- An individual written detailed report (word format) that provides thorough, evaluated, or critically reviewed technical information on all the points illustrated in the Assignment Brief and Guidance section, FAIR-U Workbook filled, and Executive Briefing power point presentation.
- A signed Student Assessment Submission and Declaration form (A test conducted on the e-learning system can fulfill this requirement).
- An oral discussion about the report and the implemented work. Instructions, date, and time for the discussion will be provided later. A witness statement or observation record is considered as evidence for this part.

NOTE1 : This assignment will be submitted through the Turnitin system, which will be used to check for both plagiarism and AI-generated content. The similarity score must not exceed 20%, and the AI-detection score must also not exceed 20%. Any submission that exceeds either of these limits will be considered a breach of academic integrity. In such cases, the student will receive a grade of “U” for the course.

Report guidelines:

The report should be written in a concise, formal business style using single spacing and font size 12 with use of headings, paragraphs and subsections as appropriate (Cover page, table of contents, and an introduction to provide an overview of your report.). The expected word limit is about 3000 words, although you will not be penalised for exceeding the total word limit. The report must be supported with research and referenced using the Harvard referencing system.

Note: Soft copies submissions should be done through the university’s eLearning system (<https://elearning.htu.edu.jo>) by the deadline assigned above.

Unit Learning Outcomes

- LO1** Understand the fundamentals of risk analysis and threat modeling to identify and mitigate security risks.
- LO2** Understand the Fundamentals of the Factor Analysis of Information Risk (FAIR) Methodology
- LO3** Conduct Quantitative Risk Analysis Using the FAIR Tool
- LO4** Understand the NIST Cybersecurity Framework , JNCISF and Jordanian cybersecurity regulations.

Assignment Brief and Guidance

Al-Hussein Technical University (HTU) has implemented a Smart University Online Examination System (SOES) to replace traditional paper-based exams. The system is used by more than six thousand students and three hundred instructors across multiple departments. The purpose of this system is to allow secure, remote and on-campus examinations while ensuring integrity, confidentiality and fairness.

System Components and Structure

The SOES consists of the following main components:

1. **User Access Portal**

Students, instructors and administrators access the system through a web-based application using their university email and password. There is no multi-factor authentication (no email OTP or mobile verification).

2. **Student Activities in the System**

Students log in to view available exams, register for them, start the exam at the scheduled time, answer questions, submit responses, and later check their grades and feedback.

3. **Instructor Activities**

Instructors log in to upload exam questions, set time limits and mark exams. They also approve grades and release them to students. Some instructors reuse old questions stored inside the database.

4. **Administrator Activities**

Administrators manage user accounts, create exams and grant roles (student, instructor, admin). They also control system settings and database backups.

5. **Databases and Sensitive Data**

The system uses a cloud-hosted database to store personal student profiles, exam questions, student answers, grades and instructor feedback. The connection between the exam application and database is sometimes unencrypted, using HTTP instead of HTTPS.

6. **Integration with Other Systems**

The SOES is integrated with the Student Information System (SIS) to automatically retrieve student data. It is also connected to a payment service where students pay exam fees using credit cards or electronic wallets. Some Application Programming Interfaces (APIs) are public and do not require authentication.

7. **Notifications and Emails**

The system send exam schedules, result notifications, and password reset messages using email and SMS. Password reset does not require identity verification.

Reported Cybersecurity Issues and Observed Incidents

Over the last semester, the IT security team observed several security concerns:

1. Students reported that they were able to log in using only their student ID number without a secure password. Some shared passwords among themselves.
2. The system recorded more than three hundred failed login attempts in less than one hour targeting instructor and admin accounts, which indicates a brute-force attack.
3. Logs show an attempt to access the question bank from an unknown internet address before the midterm exam. There is suspicion that some exam questions were leaked.
4. The connection between SOES and SIS uses unencrypted HTTP protocol which allows attackers to intercept data.
5. Some instructors store exam papers as Word files on their personal laptops and upload them from home without using the university Virtual Private Network (VPN).
6. Old student accounts of graduated students were not removed from the system, which increases the attack surface.

7. The system does not use audit logs or alert administrators when unauthorized changes or downloads occur.
8. There is no backup plan if the system is attacked during exams.

Your Role as a Cyber Risk Analyst

You have been hired by the university to perform a complete risk assessment and threat modeling process for the SOES. You are required to:

- Understand the system, its components, data flows and actors.
- Perform threat modeling using a Data Flow Diagram, STRIDE, and DREAD scoring.
- Propose mitigation controls and validate them.
- Use the FAIR methodology to quantify one selected risk scenario.
- Apply the NIST Cybersecurity Framework and Jordan National Cybersecurity Framework (JNCSE) to this case.

Activity 1 – Understanding Risk Analysis and Threat Modelling

Question 1

Define in your own words the following concepts related to information risk analysis:

- Asset
- Threat
- Vulnerability
- Risk
- Likelihood and Impact
- Difference between qualitative and quantitative risk analysis

Your explanation must be clear, relevant to the given scenario, and written in complete sentences.

Question 2

Discuss and describe the meaning of threat modelling and why it is important in cybersecurity. Then describe the main ideas and terminology of the following threat modelling methodologies: STRIDE and DREAD. Your answer should also briefly compare both methodologies by explaining when each method is used and what kind of results they produce.

Activity 2 – Threat Modelling for the SOES

Question 3

Draw a Level 1 Data Flow Diagram of the SOES based on the scenario. Your diagram should clearly show:

- External entities such as Student, Instructor, Administrator
- Main internal system processes such as Login, Upload Exam Questions, Student Exam Submission, Grade Publishing
- Data stores including User Database, Exam Question Database, Exam Results Database
- Data flows between the entities, processes and databases

You must label each process and data flow clearly using full words. No abbreviations or symbols should be used without explanation.

Question 4

Using the Data Flow Diagram you created, identify threats by applying the STRIDE methodology. Create a table in your report that includes for each part of the system:

- System component or data flow
- STRIDE category (Spoofing, Tampering, Repudiation, Information Disclosure, Denial of Service, Elevation of Privilege)
- A short description of the threat

- The asset or system component that is affected
- The table must be written clearly using full words.

Question 5

Apply the quantitative risk analysis approach and DREAD method to the threats identified in Question 4. For each threat, provide:

- A score from one to ten for each DREAD factor (Damage potential, Reproducibility, Exploitability, Affected users, Discoverability)
 - Calculation of the average DREAD value for each threat
- After completing the scoring, select the three threats with the highest scores and consider them as high-priority risks. Explain why these three are more critical than the others.

Question 6

For each of the three high-priority threats identified in Question 5, complete the following:

- Propose realistic mitigation or control measures
- Explain whether each measure is administrative, technical or physical control
- Recalculate the DREAD score after applying the mitigation.
- Explain whether the risk level is reduced and whether the mitigation is effective and critically Evaluate the results.

Activity 3 – Quantitative Risk Analysis Using the FAIR Methodology

Question 7

Describe the FAIR methodology in your own words. Identify its main components including threat event frequency, vulnerability, loss event frequency, primary loss magnitude and secondary loss magnitude. Explain how FAIR differs from traditional qualitative risk assessment.

Question 8

Justify the importance of quantifying risk instead of relying only on qualitative risk assessment. Compare quantitative and qualitative methods by describing at least three differences. You may relate your answer to the Smart Online Examination System to make it more practical.

Question 9

Choose one high-priority threat from Task 2 (for example exam question leakage, unauthorized access to admin account or interception of data between SOES and SIS). Use the FAIR methodology to conduct a basic risk analysis by defining the following values:

- Contact Frequency
- Probability of Action
- Threat Capability
- Resistance Strength
- Primary Loss Magnitude
- Secondary Loss Magnitude

Use reasonable assumptions if exact data is not available, and clearly explain each assumption.

Question 10

Using the FAIR-U Excel tool or a similar structured table, calculate and present:

- Loss Event Frequency
- Loss Magnitude
- Annualized Loss Exposure

Present your results in a clear table and analyze what each value means for the university.

Question 11

Develop a detailed FAIR analysis report for the selected threat. Your report must include:

- Explanation of the scenario you selected
- Description of all FAIR variables, assumptions and sources of data
- Final calculated results (risk values, frequencies and magnitudes)
- Interpretation of the findings and what they mean for the university risk posture
- Recommendations to reduce the risk and a short discussion of cost versus benefit

Question 12

Critically Evaluate the strengths and limitations of the FAIR methodology. Discuss at least two strengths such as realism, mathematical visibility or decision-making support, and at least two limitations such as data dependency or complexity.

Activity 4 – Application of the NIST Cybersecurity Framework (NIST CSF)

Question 13

Explain the NIST Cybersecurity Framework in your own words. Describe the five core functions which are Identify, Protect, Detect, Respond and Recover. For each function, write one or two sentences explaining its meaning and purpose.

Question 14

Using the Smart Online Examination System scenario, explain how each NIST CSF function applies in this case. For example:

- In the Identify stage, how should the university identify its digital assets, users and risks
 - In the Protect stage, what security measures should exist to protect exam data and login processes
- Provide at least one realistic example for each of the five functions.

Activity 5 – Jordan National Cybersecurity Framework (JNCSEF) and Cybersecurity Regulations

Question 15

Evaluate in details how the Jordan National Cybersecurity Framework and Jordanian cybersecurity regulations apply to the Smart Online Examination System. Your answer must include:

- An explanation of the purpose and main goals of the JNCSEF
- Identification of regulations related to personal data protection, digital examination systems or educational information security in Jordan
- Evaluation of whether the university's current practices in the scenario follow these regulations and standards
- Recommendations to improve compliance, governance or legal awareness

Learning Outcomes and Assessment Criteria			
Learning Outcome	Pass	Merit	Distinction
LO1 Understand the fundamentals of risk analysis and threat modeling to identify and mitigate security risks.	P1 Identify and describe key concepts in information risk analysis. P2 Discuss threat modeling concepts and terminology, and identify and describe the different types of threat modeling methodologies (e.g., STRIDE, DREAD).	M1 Apply threat modeling to identify potential vulnerabilities and threats in a specific system.	D1 Evaluate an information system risk using a quantitative risk analysis approach, apply mitigation measures, and re-evaluate with the applied mitigations.
LO2 Understand the Fundamentals of the Factor Analysis of Information Risk (FAIR) Methodology	P3 Demonstrate a basic understanding of the FAIR methodology and its components.	M2 Explain the importance of risk quantification and contrast it with traditional qualitative methods. or apply FAIR terminology to a risk scenario.	D2 Critically analyze the strengths and limitations of the FAIR methodology .
LO3 Conduct Quantitative Risk Analysis Using the FAIR Tool	P4 Conduct a basic FAIR risk analysis of a scenario.	M3 Analyze and present the outputs of the FAIR tool, including risk exposure values and loss event frequencies.	D3 Develop a comprehensive FAIR risk analysis report, including detailed explanations of the calculations and results. Additionally, interpret the findings to provide valuable insights into the organization's risk posture.
LO4 Understand the NIST Cybersecurity Framework , JNCSE and Jordanian cybersecurity regulations.	P5 Discuss and identify the primary components and the five core functions of the NIST Cybersecurity Framework (CSF).	M4 Discuss, with examples, how each core function of the NIST Cybersecurity Framework (NCF) is applied in a risk management strategy.	D4 Discuss and evaluate the Jordan National Cybersecurity Framework (JNCSE) and Jordanian cybersecurity regulations.